AJ SMART BIZ · DOCUMENT 06

API Reference

Every endpoint of the backend, grouped by module, with conventions, authentication and error formats.

Base URL	`http://localhost:4000/api/v1` (dev) · `https://smart-biz-api.ajtechhub.com/api/v1` (deployed)
Live docs	Swagger UI at `/api/v1/docs`, JSON at `/api/v1/docs.json`
Version / date	1.0 · 7 November 2026

Contents

1. Conventions
2. Shared — health, auth, masters, uploads
3. Theme — tenant public websites
4. Website — product marketing site
5. Admin — company workspace
6. Super Admin — platform console
7. Rate limits

1. Conventions

Envelope

```
{ "success": true,  "message": "Branch list fetched successfully",
  "data": [ ... ],  "meta": { "total": 42, "page": 1, "limit": 10, "totalPages": 5, "hasNext": true } }

{ "success": false, "message": "Validation failed",
  "errors": [ { "field": "email", "message": "\"email\" must be a valid email", "in": "body" } ] }
```

Authentication

`Authorization: Bearer <accessToken>`. Login returns `{ accessToken, refreshToken, expiresIn, user }`. Scopes: `super_admin`, `admin`, `customer`.

List queries

`?page=1&limit=10&search=&status=active&sortBy=name&sortOrder=asc` plus resource filters. `limit` ≤ 200. `sortBy` is allow-listed per resource.

Common sub-routes

`PATCH /:id/status`	Toggle `{ status: "active" | "inactive" }`
`PATCH /reorder`	Send the whole ordered id list; sets `sequence`
`GET /dropdown`	`[{ id, name }]` for selects
`POST /:id/restore`	Undo a soft delete
`DELETE /:id`	Soft delete

Status codes

200 OK · 201 Created · 202 Accepted (AI job) · 400 validation/business rule · 401 unauthenticated · 403 forbidden (permission) · 404 not found (including other tenants' ids) · 409 conflict · 429 rate limited · 500 server error.

2. Shared

Endpoint	Purpose
`GET /health`	Liveness
`POST /auth/super-admin/login`	Super admin sign-in
`POST /auth/admin/login`	Company admin sign-in
`POST /auth/refresh`	Exchange refresh token

Endpoint	Purpose
`GET /auth/me`	Profile; for admins also `permissions` map and `menus` tree
`PATCH /auth/profile`	Update own profile
`POST /auth/change-password`	Change password; clears mustChangePassword
`POST /auth/logout`	Stateless sign-out
`GET /masters/functionalities`	Feature catalogue (and icon library)
`/masters/states · /business-types · /themes · /plans`	GET /, /dropdown, /:id (any signed-in user); POST, PUT /:id, PATCH /:id/status, DELETE /:id, POST /:id/restore (super admin)
`POST /uploads/:folder`	Multipart `file`; `?accept=ico` for favicons; super admin may pass `?companyId=`. Returns path, url, filename, mimeType, size. Folders: branch, company, slider, team, gallery, service, product, category, blog, avatar, misc
`DELETE /uploads?path=`	Delete own company's file
`GET /uploads/folders`	Allowed folders

3. Theme — tenant public websites (/theme)

No token required except `/theme/me`. The tenant is resolved from `?domain=` / body `domain` / X-Forwarded-Host / Host.

Endpoint	Purpose
`GET /theme/branding`	Logo, name, description, favicon for a console login screen
`GET /theme/company-details`	Full public payload: profile, branches, slides, nav, theme, live features, contact page, `service {active, reason}`
`GET /theme/services/:slug/slots`	Slots for a date plus next free days
`GET /theme/blog · /theme/blog/:slug`	Paged archive (tag, page, limit) · post with prev/next
`POST /theme/leads`	Visit / tracking beacon
`POST /theme/testimonials`	Visitor review (held for moderation)
`POST /theme/service-leads`	Enquiry or booking (optional customer token)
`POST /theme/orders`	Place order: ids + quantities only (optional customer token)
`POST /theme/auth/register · /request-otp · /verify`	Customer sign-up / OTP / verify → token
`GET · PUT /theme/me`	Customer profile

Endpoint	Purpose
`POST /theme/me/addresses · PUT/DELETE /:id`	Saved addresses
`GET /theme/me/orders · /theme/me/services`	Order and booking history

4. Website — product marketing site (/website)

Endpoint	Purpose
`GET /website/bootstrap`	Content, plans, capabilities, business types and FAQs in one call
`GET /website/content · /plans · /capabilities · /business-types · /faqs · /templates`	Individual parts (templates accept `?design=`)
`POST /website/enquiries`	Demo or contact enquiry
`POST /website/track`	Marketing visitor beacon

5. Admin — company workspace (/admin)

Requires an `admin` token. The company is taken from the token. Each group shows the permission slug enforced.

Endpoint	Purpose · permission
`GET /admin/dashboard`	Counts, plan, quotas, features, storage
`GET · PUT /admin/company`	Company profile · company-details (PUT main admin only)
`GET /admin/company/plan · /plans`	Current plan · requestable plans · my-plan
`GET · POST /admin/company/plan-requests, POST /:id/cancel`	Plan change requests

Endpoint	Purpose · permission
`GET /admin/company/subscriptions · /transactions`	Billing history
`/admin/company/branches`	GET /, /quota, POST, GET/PUT/DELETE /:id, PATCH /:id/status; contacts at /:branchId/contacts · branch-management
`/admin/company/sliders`	CRUD, /reorder, status · slider-management
`/admin/company/theme`	GET/PUT/DELETE `?branchId` — primaryColor, secondaryColor, accentColor, mode
`/admin/company/domains`	CRUD, status · company-details (writes main admin)
`/admin/company/functionalities`	GET /, GET /:key, PATCH /:key/status, PUT /:key/settings
`/admin/company/whatsapp-numbers · /social-links`	CRUD, reorder, status
`/admin/company/about · /contact`	GET/PUT/DELETE `?branchId` (DELETE clears branch override)
`/admin/company/stats · /team · /gallery · /features · /services · /service-categories`	Card routers: GET /, PATCH /reorder, POST, PUT /:id, PATCH /:id/status, DELETE /:id
`/admin/company/testimonials`	Card router + PATCH /:id/moderation

Endpoint	Purpose · permission
`/admin/company/categories · /products`	Tree and catalogue CRUD, reorder, status; products GET /:id
`/admin/company/blog`	GET /, /summary, /tags, POST, GET/PUT/DELETE /:id, status
`/admin/company/service-leads`	GET /, /summary, /revenue, /analytics, /diary?date; PATCH /:id, PATCH /:id/booking, DELETE · service-leads
`/admin/company/orders`	GET /, /summary, /analytics, /:id; PATCH /:id/status, /:id/payment; PUT /:id · orders
`/admin/company/warehouses`	GET, POST, PUT /:id, DELETE /:id · warehouse (writes canEdit)
`/admin/company/stock`	GET /, GET/POST /movements, POST /transfer, PUT /settings, GET /analytics · warehouse
`/admin/company/invoices`	GET /meta, /products, /summary, /access, /analysis; GET /, POST (canCreate), GET/PUT/DELETE /:id (drafts); POST /:id/issue, PATCH /:id/payment, POST /:id/cancel · invoices

Endpoint	Purpose · permission
`/admin/company/customers`	GET /, /summary, GET/PUT/DELETE /:id, PATCH /:id/status · customers
`/admin/company/leads`	GET /, /summary, /analytics, /:id, /:id/visits; PATCH /:id · lead-management
`/admin/roles`	CRUD, /dropdown, status · role-management
`/admin/roles/:roleId/permissions`	GET; PUT replaces the whole matrix · menu-permission
`/admin/menus`	GET /, /tree, POST, GET/PUT/DELETE /:id · menu-permission
`/admin/admins`	CRUD, /quota, status, PATCH /:id/reset-password · admin-management

6. Super Admin — platform console (/super-admin)

Endpoint	Purpose
`GET /super-admin/dashboard`	Platform KPIs, income series
`/super-admin/companies`	GET (filters businessTypeId, stateId, planId, subscriptionStatus), POST (provision), POST /samples, GET/PUT/DELETE /:id, PATCH /:id/status, POST /:id/restore, PATCH /:id/storage, POST /:id/duplicate
`GET /super-admin/companies/:id/plan · /insights`	Plan view · business insights (`?days=`)

Endpoint	Purpose
`/super-admin/companies/:id/subscriptions`	GET, POST (assign), POST /renew, POST /change-plan, GET /change-preview, POST /:subscriptionId/cancel
`/super-admin/companies/:id/transactions`	GET, POST (record payment)
`POST /super-admin/companies/:id/ai-content · GET /:jobId`	Start AI content job (202; 409 if running) · poll
`/super-admin/companies/:companyId/branches · /domains · /sliders · /admins`	Tenant routers re-mounted for a chosen company
`/super-admin/subscriptions`	GET /, /summary, POST /run-due, GET /:id, /:id/events; POST /:id/transition, /suspend, /resume, /cancel, /expire, /start-now, /reactivate, /extend; PATCH /:id/auto-renew
`/super-admin/plan-requests`	GET /, POST /:id/approve, POST /:id/reject
`/super-admin/super-admins`	CRUD, status, PATCH /:id/reset-password (root protected)
`/super-admin/marketing`	content (GET, GET/PUT /:key), faqs, templates (CRUD), enquiries (GET, GET/PATCH /:id), leads (GET, /summary, /analytics, GET/PATCH /:id, /:id/visits)
`/super-admin/leads`	Cross-tenant leads: GET /, /summary, /analytics, /:id, /:id/visits
`/super-admin/customers · /summary`	Cross-tenant customers

7. Rate limits (production)

Scope	Limit
`/auth/*/login`	30 per 15 min per IP
`/theme reads`	120 per 5 min
`/theme/leads`	300 per 5 min
`/theme/testimonials`	5 per hour

Scope	Limit
`/theme/service-leads`	12 per hour
`/theme/orders`	15 per hour
`/theme/auth/*`	10 per 15 min
`/website reads`	600 per 5 min
`/website/enquiries`	10 per 15 min

> **Server-side callers share an IP**
> The websites call the API from their own server, so per-IP limits apply to the container unless `X-Forwarded-For` is trusted end to end.